

BGP: Authentication, Hijacking & IP Spoofing

1. BGP Basics

What is BGP?

The internet is a collection of independently administered networks called Autonomous Systems (ASes). BGP (Border Gateway Protocol) is the exterior gateway protocol that connects them:

- BGP exchanges routing and reachability information between ASes across the internet.
- It is a path-vector protocol — each router maintains a table of distances and output interfaces to remote networks, and makes routing decisions based on paths, policies, and rules configured by administrators.
- **IBGP (Internal BGP)**: Sessions between routers within the same AS.
- **EBGP (External BGP)**: Sessions between routers in different ASes. This is what connects the internet together.

BGP peers / neighbors: Two routers that establish a BGP connection are called peers or neighbors. An EBGP session runs over TCP (port 179) between routers in different ASes.

Key BGP Tables

- **Routing Table (show ip route)**: Lists all routes the router knows, learned from all protocols (kernel, static, RIP, OSPF, BGP, etc.). 'B' prefix = BGP-learned route.
- **BGP Table (show ip bgp)**: Lists only routes learned specifically through BGP, along with next-hop, metric, local preference, weight, and AS path.

2. BGP Security Issues

Fundamental Trust Problems

BGP was designed for a cooperative internet and has no built-in authentication or integrity protection by default. This creates three core vulnerabilities:

- A router may be talking to the wrong device — an intruder that has inserted itself into the path.
- An unauthorized AS can advertise (originate) prefixes it does not own, rerouting traffic meant for another network.
- BGP update messages can be modified in transit by an on-path attacker.

TCP Reset Attacks on BGP Sessions

BGP sessions run over TCP. An attacker can disrupt a BGP session by injecting a forged TCP RST (reset) packet:

- If AS 100 sends a TCP RST to AS 200, AS 200 tears down the TCP session with AS 100 — losing the BGP peering.
- An attacker can forge (spoof) a TCP RST targeting any active BGP session, interrupting traffic flow between the two ASes.
- **What the attacker needs:** The correct source/destination IP addresses, BGP port (179), and a valid sequence number.
- Since TCP sequence numbers are 32-bit, the attacker can simply send packets covering all possible sequence numbers — this takes approximately one minute at typical rates.

Why this works: The BGP session has no way to verify that the RST packet came from the legitimate peer rather than a spoofed packet. TCP alone provides weak source authentication.

3. TCP MD5 Authentication for BGP

MD5 Hash Algorithm — Background

MD5 is a cryptographic hash function used as the authentication mechanism for BGP sessions:

- **Input:** Arbitrary-length message.
- **Output:** 128-bit fixed-length message digest (fingerprint).
- Computationally hard to find two different messages with the same digest (collision resistance).
- Computationally hard to reconstruct the original message from its digest (pre-image resistance).

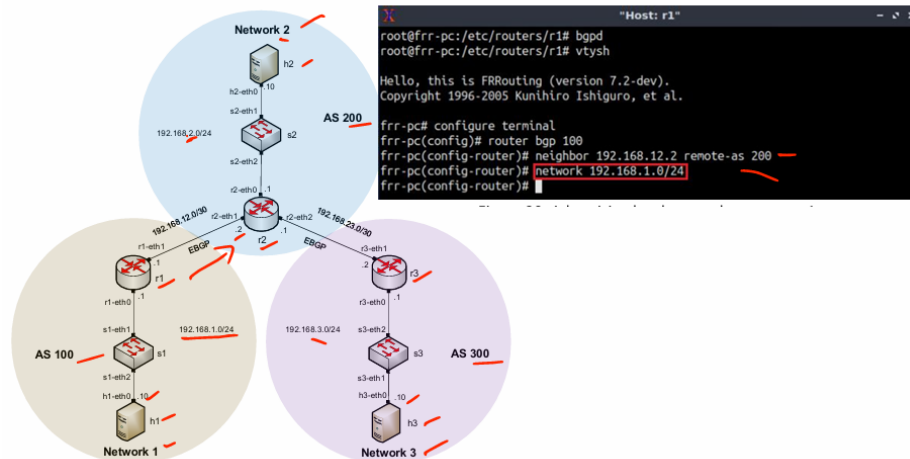
How TCP MD5 Authentication Works

Each BGP TCP segment is signed using a shared secret key known only to the two peers:

- **Sender:** hashes the message, encrypts the digest with the shared key, and appends it to the TCP segment.
- **Receiver:** independently hashes the received message the same way, decrypts the received digest using the shared key, and compares the two values.
- If the digests do not match, the segment is silently dropped — the session is not disrupted but the forged packet is rejected.

Key defense: A forged RST packet from an attacker will not have a valid MAC (message authentication code) because the attacker does not know the shared secret. The router discards it.

BGP Authentication — How It Works in Practice



bgpd starts the BGP daemon.
 vtysh opens FRRouting CLI.
 configure terminal enters configuration mode.

1. Configure BGP on r1

router bgp 100

neighbor 192.168.12.2 remote-as 200

network 192.168.1.0/24

2. Configure BGP on r3

router bgp 300

neighbor 192.168.23.1 remote-as 200

network 192.168.3.0/24 r3 advertises its local network:

3. Configure BGP on r2

router bgp 200

neighbor 192.168.12.1 remote-as 100

neighbor 192.168.23.2 remote-as 300

network 192.168.2.0/24

4. From h3: ping 192.168.1.10

h3 in Network 3 is trying to reach h1 in Network 1.

Ping is successful because BGP has exchanged routes correctly.

So Network 3 knows how to reach Network 1.

Set BGP password / MD5 authentication

On r1:

neighbor 192.168.12.2 password 123

On r2:

```
neighbor 192.168.12.1 password 123  
neighbor 192.168.23.2 password 123
```

On r3:

```
neighbor 192.168.23.1 password 345
```

Meaning:

BGP neighbors must use the **same password** to form connection.

r1 and r2 both use password 123, so their BGP session works.

But r2 uses password 123 for r3, while r3 uses password 345.

So r2 and r3 password does **not match**.

From h3:

```
ping 192.168.1.10
```

Meaning:

r3 does not learn routes to 192.168.1.0/24 or 192.168.2.0/24.

That is why h3 cannot reach h1.

4. BGP Hijacking

What is BGP Hijacking?

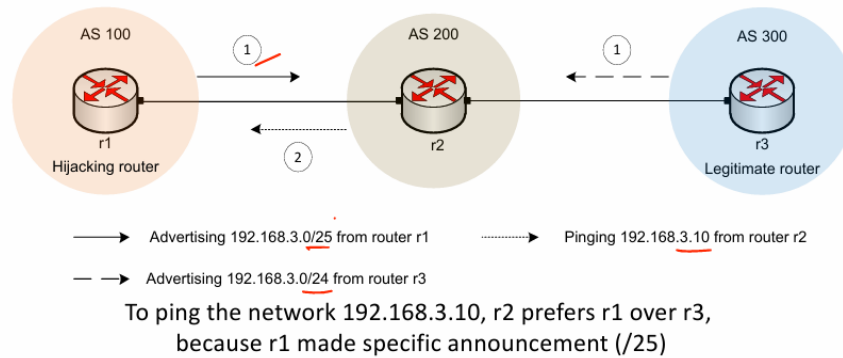
BGP hijacking occurs when an unauthorized network (AS) announces (originates) IP prefixes that belong to another network. Because BGP was designed on trust, other routers may accept and propagate these false announcements, redirecting internet traffic to the attacker.

- All traffic destined for the hijacked prefix is rerouted through the attacker's network.
- Traffic can be intercepted, dropped (causing outage), or passed on silently (surveillance).

Two Methods of BGP Prefix Hijacking

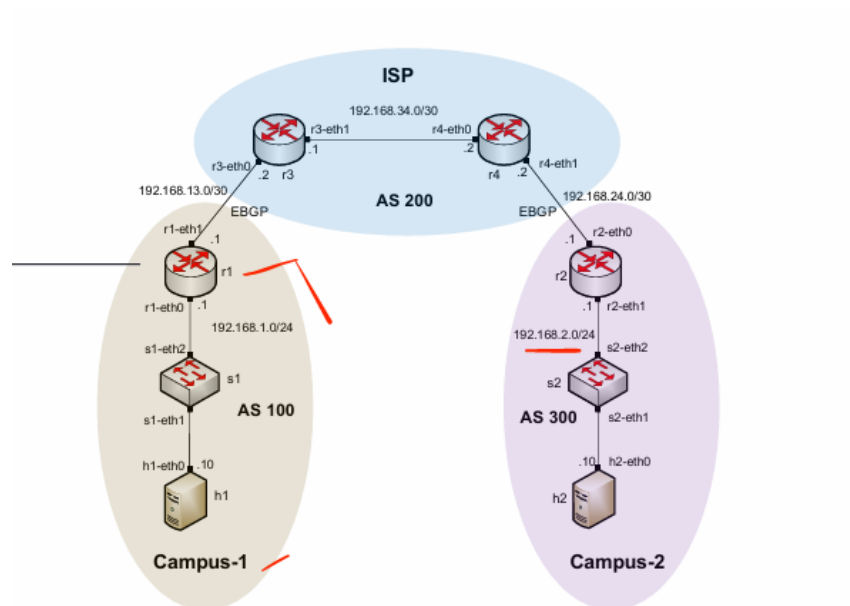
- **Method 1 — More-specific prefix (/25 vs /24):** BGP always prefers the most specific (longest prefix) route. If the legitimate router advertises 192.168.3.0/24 but the hijacker advertises 192.168.3.0/25, all routers choose the hijacker's more specific route — even though the hijacker has no legitimate claim to it.
- **Method 2 — Shorter AS path:** If two routers advertise the same prefix (/24), BGP prefers the route with the fewest hops. A hijacker physically closer to a transit AS will win path selection even for a prefix it does not own.

Why BGP accepts these announcements: BGP has no built-in mechanism to verify whether an AS actually owns the prefix it is advertising. Any AS can claim any prefix.



5. Mitigating BGP Hijacking

IP Prefix Filters



Flow of commands and meaning

1. r1 performs BGP hijack

On router r1:

configure terminal

router bgp 100

network 192.168.2.0/24

Meaning:

r1 is in **AS 100**, but it wrongly advertises:

192.168.2.0/24

This network actually belongs to **Campus-2 / AS 300**.
So r1 is pretending: "I have route to 192.168.2.0/24."

2. Check BGP table on ISP router r3

On **router r3**:

show ip bgp

Meaning:

r3 checks which BGP routes it learned.

Before filtering, r3 learns 192.168.2.0/24 from r1 also.

So r3 may choose next hop:

192.168.13.1

That is r1.

This means traffic for Campus-2 is now going toward the hijacker r1.

3. Capture traffic on r1

On **router r1**:

tcpdump -i r1-eth1

Meaning:

r1 starts capturing packets on interface r1-eth1.

This is done to prove that traffic meant for victim network is coming to r1.

4. Ping victim from ISP side

On **router r3**:

ping 192.168.2.10

Meaning:

r3 tries to reach victim host 192.168.2.10 in Campus-2.

But because r1 hijacked 192.168.2.0/24, the packets are wrongly sent toward r1.

Ping fails with:

Destination Net Unreachable

5. tcpdump proves hijack

On r1, tcpdump shows packets like:

192.168.13.2 > 192.168.2.10 ICMP echo request

Meaning:

Traffic for victim 192.168.2.10 is reaching r1.

So hijack is successful.

6. Configure prefix filter on ISP router r3

On **router r3**:

configure terminal

ip prefix-list campus1-in seq 10 permit 192.168.1.0/24

Meaning:

This prefix list says:

Only allow Campus-1/r1 to advertise:

192.168.1.0/24

Any other route from r1 will be denied automatically.

7. Apply prefix list to r1 neighbor

On **router r3**:

router bgp 200

neighbor 192.168.13.1 prefix-list campus1-in in

Meaning:

Apply this filter on routes coming **inbound** from r1.

So if r1 advertises:

192.168.2.0/24

r3 will reject it.

8. Verify BGP table again

On **router r3**:

show ip bgp

Meaning:

Now r3 checks routes again.

After filtering:

192.168.1.0/24 → next hop 192.168.13.1

192.168.2.0/24 → next hop 192.168.34.2

Now 192.168.2.0/24 goes to the real AS 300 router, not to r1.

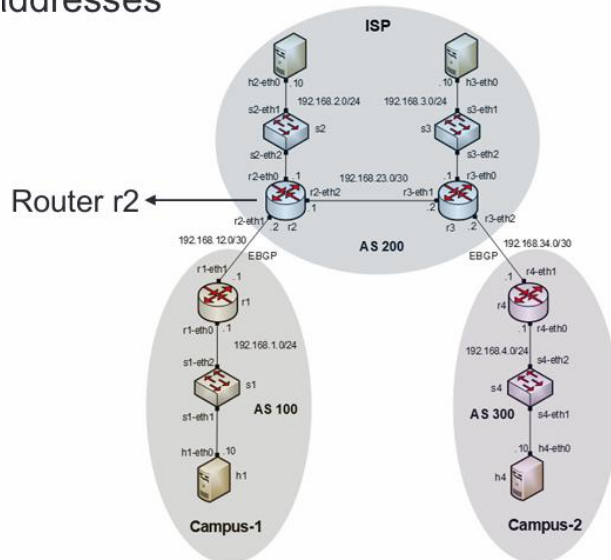
RPKI — Resource Public Key Infrastructure

IP prefix filters must be manually configured and maintained per-neighbor — they do not scale to the full internet. RPKI is the cryptographic solution:

- RPKI allows IP address holders to cryptographically certify which AS numbers are authorized to originate their prefixes (Route Origin Authorizations, or ROAs).
 - Routers that validate RPKI data will reject BGP announcements that contradict published ROAs.
 - RPKI is considered the long-term fix for BGP hijacking at internet scale.
-

6. IP Spoofing

addresses



What is IP Spoofing?

IP spoofing is the practice of sending IP packets with a source address different from the sender's actual IP address. The IP header source field is not verified by routers — any host can write any IP address as the source:

- Primarily used to hide the true origin of an attack.
- Used to make responses from other hosts be sent to the victim (reflection/amplification attacks).
- Main use case: launching Denial of Service (DoS) attacks where the victim receives traffic that appears to come from legitimate sources.

Example: Attacker (Host A) sends packets with source IP = Host C's address to Host B. Host B responds to Host C (the victim) with 100 GB of data — even though Host C never made a request.

IP Spoofing checking

Step 1: h1 spoofs h4's IP address

On h1:

```
ifconfig lo 192.168.4.10
```

Meaning:

h1 adds 192.168.4.10 to its loopback interface.

But 192.168.4.10 is actually h4's IP address.

So h1 is preparing to send packets with this fake source IP:

Source IP = 192.168.4.10

This is called IP spoofing.

Step 2: h1 pings h2 and h3 using spoofed source IP

On h1:


```
fping --src 192.168.4.10 192.168.2.10 192.168.3.10
```

Meaning:

h1 sends ICMP echo request packets to:

192.168.2.10 → h2

192.168.3.10 → h3

But the source IP inside the packet is fake:

192.168.4.10 → h4

So h2 and h3 think the ping came from h4, not h1.

Step 3: Why h1 shows “unreachable”

Output on h1:

192.168.2.10 is unreachable

192.168.3.10 is unreachable

Meaning:

h1 does not receive the replies.

That is expected because h2 and h3 send replies to the spoofed source IP:

192.168.4.10

So the replies go to h4, not back to h1.

Step 4: h4 receives unwanted replies

On h4, tcpdump shows:

IP 192.168.2.10 > 192.168.4.10: ICMP echo reply

IP 192.168.3.10 > 192.168.4.10: ICMP echo reply

Meaning:

h4 is receiving ping replies from h2 and h3.

But h4 never sent the ping requests.

So h4 is the victim. This is a reflection DoS attack because h1 uses h2 and h3 to send traffic toward h4.

Step 5: ISP applies filter on router r2

Router r2 is the ISP edge router connected to Campus-1.

The ISP wants to prevent Campus-1 from sending fake source IPs.

Campus-1 should only send packets with source IP:

192.168.1.0/24

So on r2:

```
iptables -A FORWARD -s 192.168.1.0/24 -i r2-eth1 -j ACCEPT
```

Meaning:

If a packet comes from Campus-1 interface r2-eth1 and its source IP belongs to:

192.168.1.0/24

then accept it.

This allows legitimate Campus-1 traffic.

Step 6: Drop all other source IPs from Campus-1

On r2:

```
iptables -A FORWARD -s 0/0 -i r2-eth1 -j DROP
```

Meaning:

If any other packet comes from Campus-1 interface r2-eth1 with a source IP not allowed above, drop it.

So if h1 sends a packet with fake source:

192.168.4.10

r2 drops it because Campus-1 is not allowed to use 192.168.4.0/24.

Step 7: Attack after filter

Again on h1:

```
fping --src 192.168.4.10 192.168.2.10 192.168.3.10
```

Now the packet reaches router r2.

r2 checks:

Source IP = 192.168.4.10

Incoming interface = r2-eth1

But Campus-1 should only send:

192.168.1.0/24

So r2 drops the spoofed packet.

Step 8: Capture traffic on h4

On h4:

```
tcpdump -i h4-eth0
```

Meaning:

h4 listens for incoming packets.

After the filter, h4 should not receive ICMP replies from h2 and h3 because spoofed packets are blocked at r2.

So the DoS attack is prevented.

7. Anti-Spoofing — Route Filtering

What is Route Filtering?

Route filtering selectively identifies which routes a router will accept or advertise to/from its neighbors. Applied at the ISP level, it can also block packets with spoofed source IPs that could not legitimately arrive on a given interface:

- Manipulate traffic flows to enforce routing policy.
- Reduce routing table memory usage.
- Improve security by blocking packets whose source addresses don't match the expected prefix for that link.